

Active Directory

- ما هو ال Active Directry
- هو ال Domain controller بيتحكم ف كل اجهزه الشركه من جهاز واحد اساسي
- لو شركة فيها 500 موظف:
- من غير AD → لازم مسؤول الشبكة يروح لكل جهاز يعمل حساب ويديله صلاحيات.
- مع AD → بيتعمل حساب واحد للمستخدم في ال AD، وأيّا كان الجهاز اللي يدخل منه، يلاقي نفسه عنده نفس الصلاحيات.

Active Directory

- This controller is called Domain Controller
- Domain Controller is Feature or tool inside the Windows Server as
- Windows server is used to control all the network with all the permission
- Suppose that you need to install program or tool for all the devices , just one click on Domain Controller , everything will be downloaded for 1,000 device

- ال Domain controller دا يعتبر العقل المدبر للشركه المدبر بمعنى اصح
- بيبقي عباره عن اداه داخل ال Windows Server
- ليه اصدارات كتير اشهرهم 2008 , 2012 , 2016 , 2022 , 2025
- لسيرفر ده بيتحكم في كل الأجهزة اللي متوصلة بالشبكة، سواء صلاحيات أو إعدادات أو برامج.

ال LDAP دا بروتوكول داخل ال Active Directry

- ال Windows Server فيه مميزات أساسية:
- ال Active Directory (التحكم في الأجهزة واليوزرات)
- ال Kerberos (بروتوكول أمان بياكد إن اليوزر هو فعلاً الشخص الصح)

- Group Policy is a feature that controls the permissions of users to do and not to do

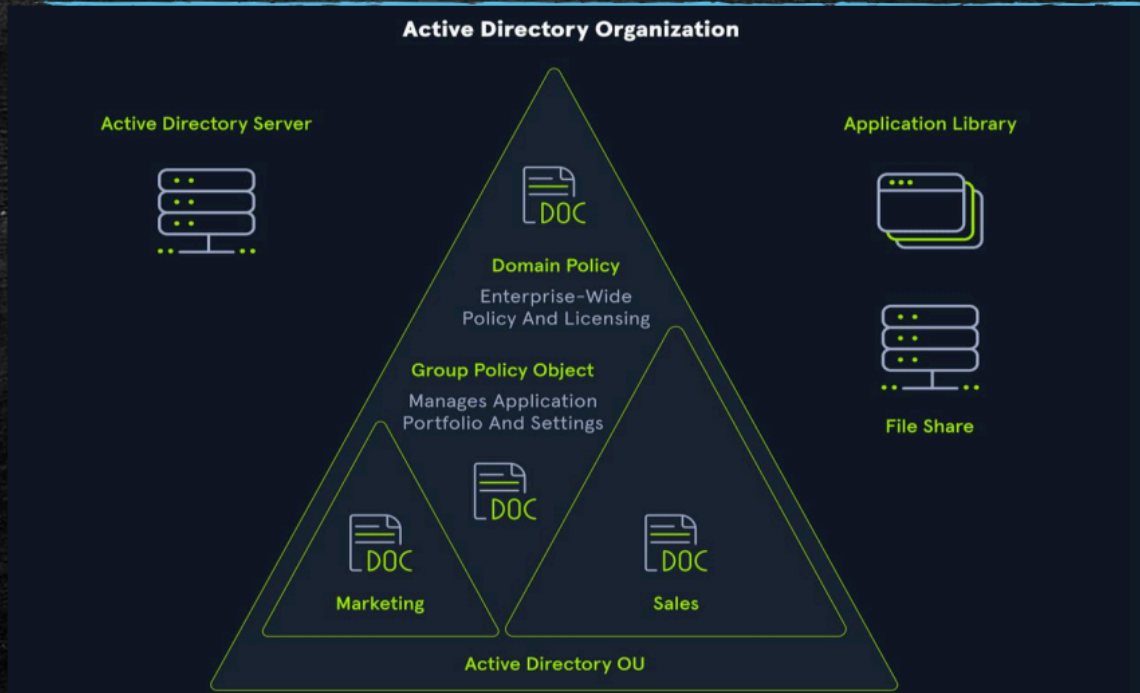
- في ميزة اسمها **Group Policy**، ودي اللي بتحدد كل يوزر يقدر يعمل إيه وميقدرش يعمل إيه

Active Directory

- Now IT can control the Whole number of devices in the network as
- Can create groups for IT and another one for the HR and another one for Managers
- Not Only That ,
- They can make some data or files Sharable as :
- Can make directory or folder only for managers
- And another one for HR

- الـ IT يقدر يتحكم في كل الأجهزة اللي موجودة على الشبكة.
- يقدر يعمل **Groups** زي مجموعة للـ IT، ومجموعة للـ HR، ومجموعة للمديرين.
- كمان يقدر يحدد مين يشارك بيانات أو ملفات معينة.
- مثلاً: يعمل فولدر يفتح للمديرين بس، أو فولدر تاني للـ HR بس.

Active Directory



- كل جروب من دول اسمه Organizational Unit
- ال Domain policy دي بتتحكم كل واحد يعمل اي
- يعني لو أحمد من HR → يتخط في OU بتاعت HR
- وبالتالي هياخد صلاحيات الـ HR كلها

Active Directory

- All Groups and Organizational units are included inside something called Domain
- The domain is Identifier for the company as `test.local` or `master.com` etc...
- These domains are part of Something called Forest
- Forest is collection of domains

- الـ OUs كلها بتبقى جوه Domain
- الدومين ده بيمثل الشركة (زي `test.local`)

- ولو عندك كذا دومين → بيتجمعوا في حاجة اسمها Forest

Active Directory

- If we need some contact between two forests for example:
- Facebook company bought WhatsApp company
- Facebook had Forest called (Facebook) and needed to merge WhatsApp Company in it then used something called Trust link
- Trust links make it easy for any domain in Facebook to access and communicate with any domain in whatsapp

- لو شركتين اندمجوا (زي Facebook و WhatsApp):
- فيسبوك عندها Forest.
- واتساب عندها Forest.
- بيعملوا بينهم **Trust Link** عشان يقدرُوا يشتغلوا مع بعض.

Active Directory

- Every Organizational Unit contains users and computer
- To reach any user in any Organizational unit or group then you need the address or the path of this user
- Suppose Ahmed in HR Need to Talk with John Managers
- Ahmed Need to go to the full path of John to be able to talk with him

- جوا كل OU فيه يوزرز وأجهزة
- عشان توصل لشخص معين، لازم تعرف العنوان الكامل بتاعه في الـ AD.
- مثال: أحمد (HR) عايز يتواصل مع جون (Manager).

- The Path or the address in active directory is called Distinguished Name (DN)
- This path or (DN) is used of Ahmed in different domain than John then needs to use Common Name

• العنوان الكامل اسمه (DN) Distinguished Name.

• ولو كانوا في دومينات مختلفة → يستخدموا (CN) Common Name.

Active Directory

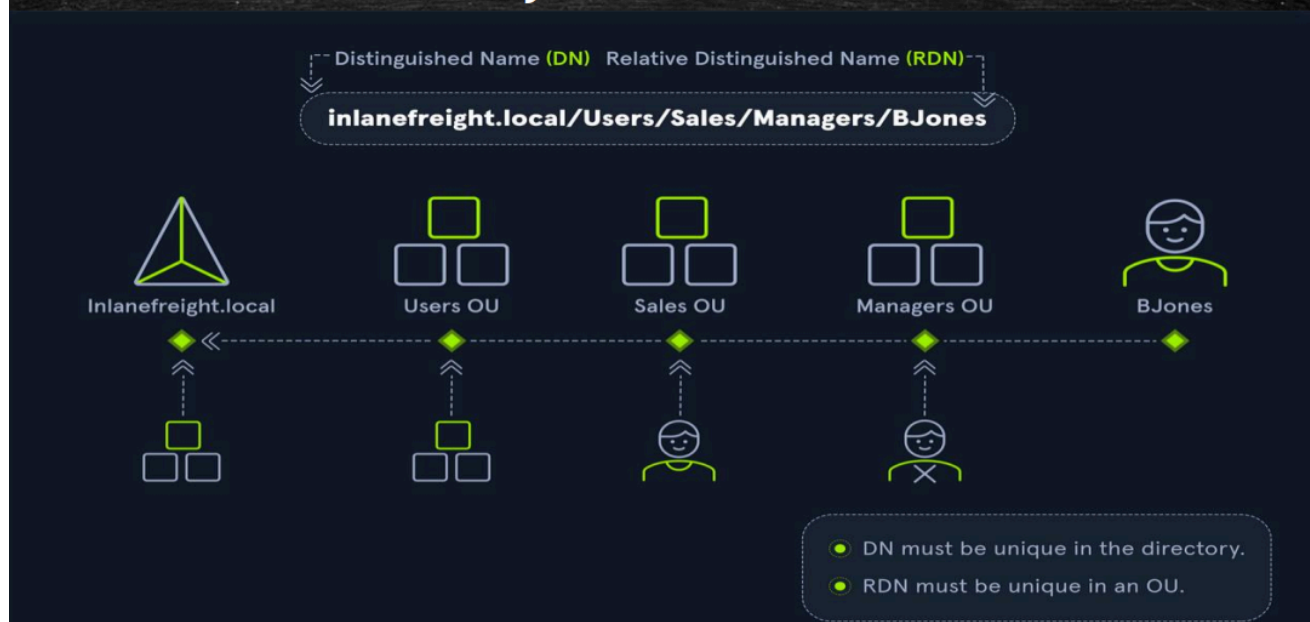
- But what if they are in the Organizational Unit
- They Would Use Relative Distinguished Name (RDN)

• لو هما في نفس الـ OU → ممكن يختصروا ويستخدموا Relative Distinguished**

• Name (RDN)**.

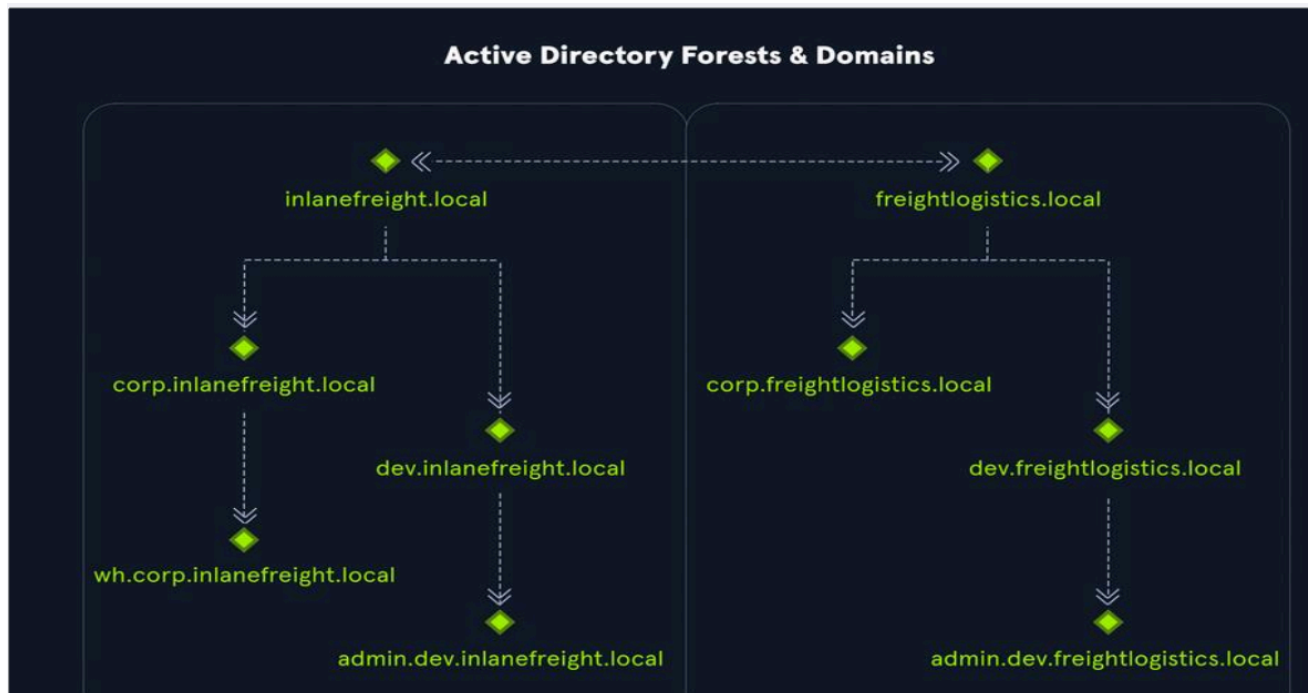
🔗 نفس حوار الـ absolute path والـ relative path ف الـ linux

Active Directory



• رسمة بتوضح العلاقة بين:

- OU
- Domain
- Forest



• مثال علی شرکتین:

- inlanefreight.local
- freightlogistics.local

- إزاي يدمجوا الـ Forests مع بعض.
- لازم الادمن يكت الـ path كامل لان مش نفس الشركه

Active Directory

- Now let's get some definitions

Object:

- An object can be defined as ANY resource present within an Active Directory environment such as OUs, printers, users, domain controllers, etc.

Attributes

Every object in Active Directory has an associated set of attributes used to define characteristics of the given object. A computer object contains attributes such as the hostname and DNS name. All attributes in AD have an associated LDAP name that can be used when performing **LDAP** queries, such as displayName for Full Name and givenName for First Name.

- أي حاجة جوا Active Directory اسمها **Object** (زي يوزر، جهاز، برنتر، OU...).
- كل Object ليه **Attributes** (خصائص) بتوصفه.
- مثال: جهاز كومبيوتر له Hostname و DNS name.
- كل Attribute ليه اسم في LDAP زي displayName (اسم العرض) أو givenName (الاسم الأول).

Active Directory

Domain : is a logical group of objects such as computers, users, OUs, groups, etc. We can think of each domain as a different city within a state or country. Domains can operate entirely independently of one another or be connected via trust relationships.

Forest : is a collection of Active Directory domains. It is the topmost container and contains all of the AD objects introduced below, including but not limited to domains, users, groups, computers, and Group Policy objects. A forest can contain one or multiple domains and be thought of as a state in the US or a country within the EU. Each forest operates independently but may have various trust relationships with other forests.

- الـ **Domain** = مجموعة Objects زي مدينة.
- الـ **Forest** = مجموعة Domains زي دولة.
- الـ Domains ممكن تشتغل لوحدها أو يبقى فيه **Trust** بينهم.

Active Directory

Security principals

Security principals are anything that the operating system can authenticate, including users, computer accounts

Security Identifier (SID)

A security identifier, or SID is used as a unique identifier for a security principal or security group. Every account, group, or process has its own unique SID, which, in an AD environment, is issued by the domain controller and stored in a secure database

- ال **Security Principal** = أي حاجة السيستم يقدر يعملها Authenticate (يوزر أو جهاز).
- كل واحد ليه **SID – Security Identifier** زي الرقم القومي.
- ال Domain Controller هو اللي بيصدر ال SID ويحفظه.

Active Directory

Distinguished Name (DN)

A Distinguished Name (DN) describes the full path to an object in AD (such as cn=bjones, ou=IT, ou=Employees, dc=inlanefreight, dc=local).

In this example, the user bjones works in the IT department of the company Inlanefreight, and his account is created in an Organizational Unit (OU) that holds accounts for company employees.

The Common Name (CN) bjones is just one way the user object could be searched for or accessed within the domain.

- AD. Object العنوان الكامل لأي **DN**.
- مثال:
- ده معناه: الموظف bjones في OU IT اللي جوا Employees OU في الدومين .inlanefreight.local
- **CN (Common Name)** = الاسم اللي نستخدمه للبحث جوه الدومين.

Active Directory

Relative Distinguished Name (RDN)

A Relative Distinguished Name (RDN) is a single component of the Distinguished Name that identifies the object as unique from other objects at the current level in the naming hierarchy.

In our example, bjones is the Relative Distinguished Name of the object. AD does not allow two objects with the same name under the same parent container, but there can be two objects with the same RDNs that are still unique in the domain because they have different DNs.

For example, the object cn=bjones,dc=dev,dc=inlanefreight,dc=local would be recognized as different from cn=bjones,dc=inlanefreight,dc=local.

- واحد في المستوى الحالي Object يميز DN جزء من الـ RDN.
- ما ينفعش يبقى فيه اثنين بنفس الـ RDN في نفس المكان.
- لكن ممكن يكون فيه اثنين بنفس الاسم في أماكن مختلفة (عشان DN كامل مختلف).

Active Directory

sAMAccountName

The sAMAccountName is the user's logon name. Here it would just be bjones. It must be a unique value and 20 or fewer characters.

userPrincipalName

The userPrincipalName attribute is another way to identify users in AD. This attribute consists of a prefix (the user account name) and a suffix (the domain name) in the format of bjones@test.local.

This attribute is not mandatory.

- Unique اسم الدخول القديم، قصير (20 حرف كحد أقصى)، لازم يكون sAMAccountName.
- UPN – userPrincipalName: شكل حديث لتسجيل الدخول username@domain .
- مثال: bjones@test.local .

Active Directory

Group Policy Object (GPO)

Group Policy Objects (GPOs) are virtual collections of policy settings. Each GPO has a unique GUID.

A GPO can contain local file system settings or Active Directory settings.

GPO settings can be applied to both user and computer objects. They can be applied to all users and computers within the domain or defined more granularly at the OU level.

- الـ **GPO** = مجموعة سياسات وصلاحيات.
- بتتحكم في اليوزرز والأجهزة.
- ممكن تتطبق على الدومين كله أو OU معينة.
- مثال:
- منع يوزر يغير Wallpaper.
- منع تشغيل برنامج معين.

Active Directory

Service Principal Name (SPN)

A Service Principal Name (SPN) uniquely identifies a service instance.

They are used by Kerberos authentication to associate an instance of a service with a logon account, allowing a client application to request the service to authenticate an account without needing to know the account name.

- الـ **SPN** = اسم يميز خدمة معينة جوا الشبكة.
- بيستخدمه Kerberos عشان يعرف الخدمة دي مربوطة بأي حساب.
- مثال: IIS أو SQL Server لازم يكون ليهم SPN.

Active Directory

Access Control List (ACL)

An Access Control List (ACL) is the ordered collection of Access Control Entries (ACEs) that apply to an object.

Access Control Entries (ACEs)

Each Access Control Entry (ACE) in an ACL identifies a trustee (user account, group account, or logon session) and lists the access rights that are allowed, denied, or audited for the given trustee.

-
- **ACL – Access Control List** = Object قائمة صلاحيات لأي
- **ACE – Access Control Entry** جواها
- كل ACE يحدد:
- مين (يوزر أو جروب).
- إيه الصلاحيات المسموحة أو المرفوضة.

Active Directory

Active Directory Users and Computers (ADUC)

ADUC is a GUI console commonly used for managing users, groups, computers, and contacts in AD. Changes made in ADUC can be done via PowerShell as well.

- **ADUC – Active Directory Users and Computers** ال
- أداة رسومية لإدارة اليوزرز والجروبات والأجهزة.
- نفس التعديلات ممكن تتعمل باستخدام PowerShell.

Active Directory

NTDS.DIT

The NTDS.DIT file can be considered the heart of Active Directory. It is stored on a Domain Controller at C:\Windows\NTDS\ and is a database that stores AD data such as information about user and group objects, group membership, and, most important to attackers and penetration testers, the password hashes for all users in the domain.

Once full domain compromise is reached, an attacker can retrieve this file, extract the hashes, and either use them to perform a pass-the-hash attack or crack them offline using a tool such as Hashcat to access additional resources in the domain.

- ده الملف الأساسي بتاع Active Directory.
- مكانه: C:\Windows\NTDS .
- بيخزن:
 - بيانات يوزرز.
 - بيانات جروبات.
 - عضويات.
- Password Hashes (أهم حاجة).
- الهاكر لو وصله يقدر يعمل هجمات زي Pass-the-Hash أو يفك ال Hashes بأدوات زي Hashcat.

Active Directory

Kerberos is service that is responsible for authentication for the users as there are two methods for authenticating users

1- **NTLM service** or protocol , with this protocol user can login with username and password but can be cracked with man in the middle attack (Local or when Kerberos Not Available)

2- **Kerberos protocol** which provides high level of encryption and tickets to authenticate users

- طريقتين أساسيين للمصادقة:
 1. **NTLM**: ضعيف وسهل يتكسر ، Username + Password قديم، بيعتمد على
 2. **Kerberos**: وتشفير Tickets أحدث وأقوى، بيعتمد على

Active Directory

Kerberos Deal with two Tickets

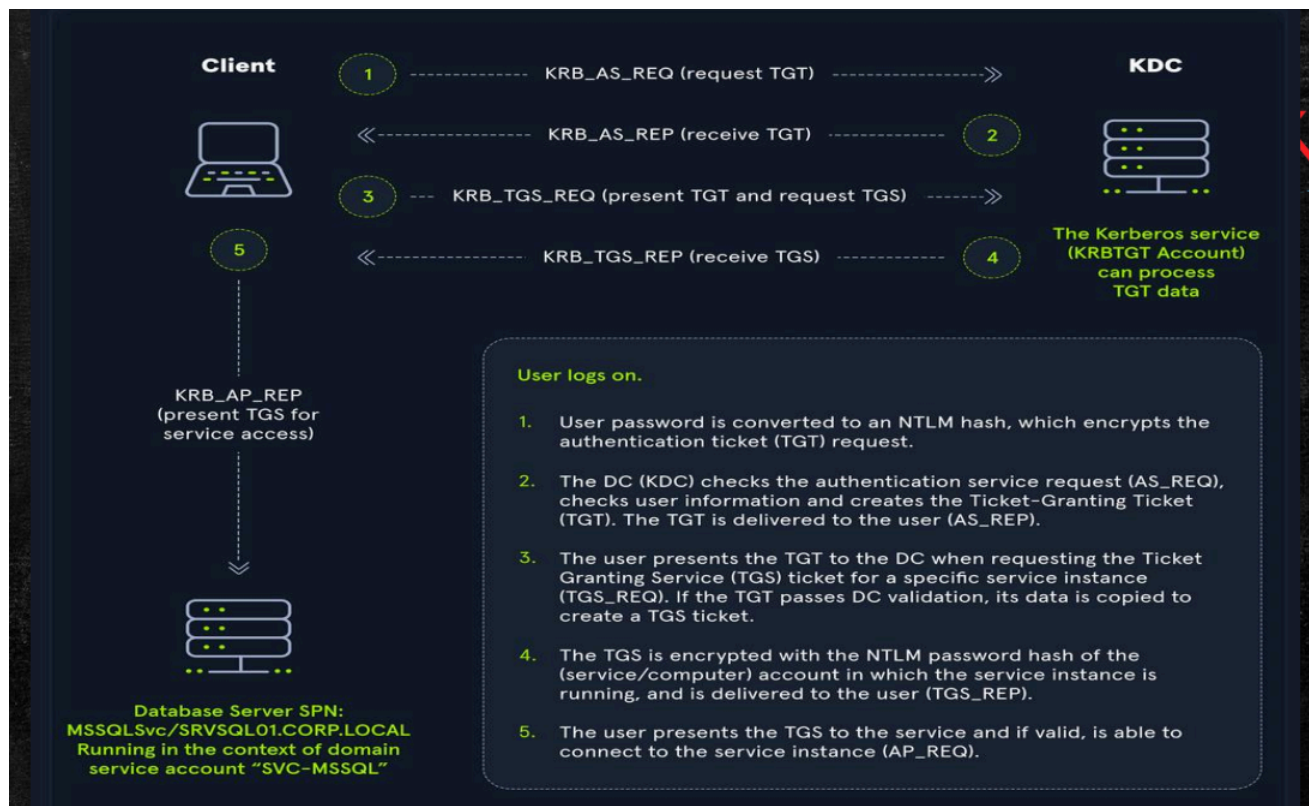
- 1- TGT (Ticket Granting Ticket)
- 2- TGS (Ticket Granting Service)

TGT responsible for authentication or checking if the user is already found inside kerberos database

TGS responsible for Authorization or checking if user is permitted to access specific service or not

• نوعين تذاكر:

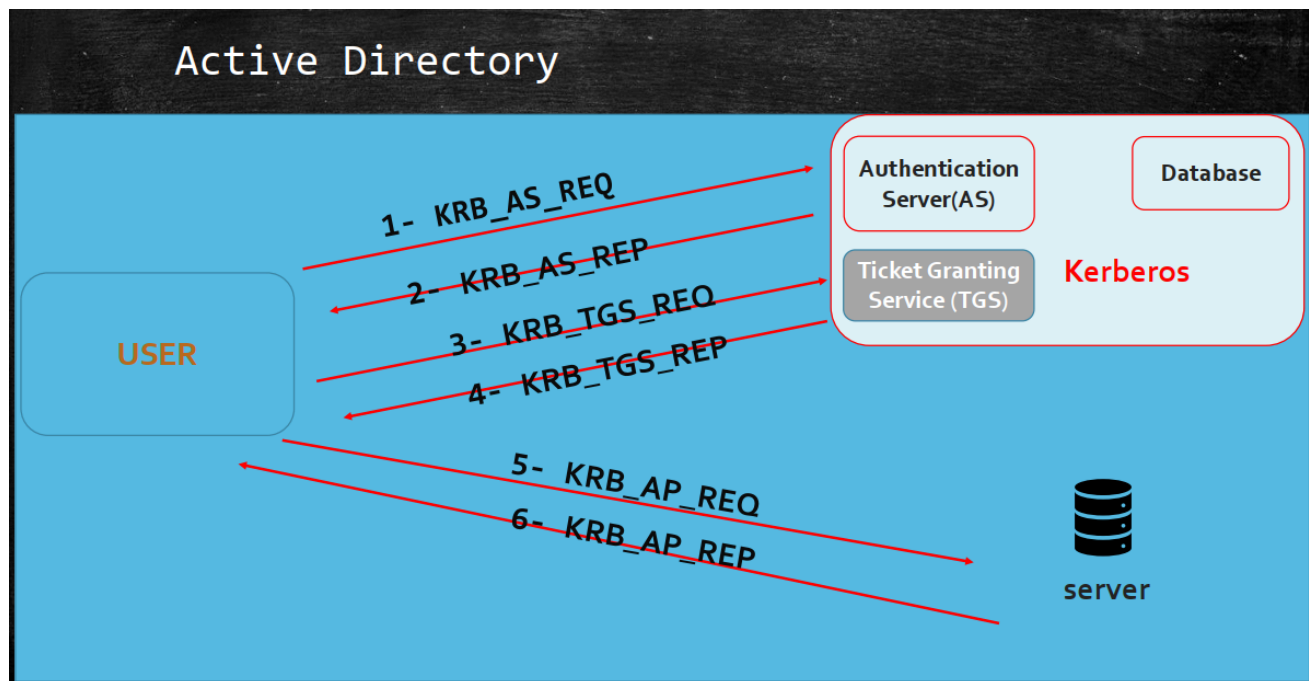
1. **TGT – Ticket Granting Ticket:** يتأكد إن اليوزر موجود في قاعدة البيانات.
2. **TGS – Ticket Granting Service:** يتأكد من صلاحيات اليوزر على خدمة معينة.



• المكونات:

- Authentication Server (AS).
- Database.
- Ticket Granting Service (TGS).

- User.



Active Directory

1- user create initial request for the KDC by providing the timestamp encrypted with his password's hash (NTLM hash) and his username hossam

2- KDC ensures that the password is correct by decrypting the timestamp with Hossam's password stored in the database and ensures they are the same (Time must be 5 minutes for max)

3- Once ensured then KDC provides

- TGT encrypted with secret key
- Session key encrypted by user's password provided

1. اليوزر يطلب من KDC تذكرة: Username + Timestamp يبعث بالـ Hash بتاع الباسورد.

2. الـ KDC يفك التشفير ويتأكد من صحة الباسورد. لازم فرق التوقيت ≥ 5 دقائق.

3. لو صح $\rightarrow$ KDC يدي اليوزر:

- متشفّر بمفتاح سري TGT.
- متشفّر بباسورد اليوزر Session Key.

Active Directory

After user getting the TGT need to get TGS

4- User sends Authenticator contains:

- 1- Client Principal Name
 - 2- Current timestamp
- Then encrypt the Authenticator with session key provided in step 3
 - And send TGT With Authenticator

4. اليوزر عايز خدمة (مثلاً IIS).

- يجهز **Authenticator** فيه اسمه + Timestamp جديد.
- يشفره بالـ Session Key اللي معاه.
- بيعت Authenticator + TGT للـ KDC.

Active Directory

5- After that KDC provides the TGS to the user but encrypted with secret key

And new session key but encrypted with last session key

6- After the user gains the TGS now they can access the service as iis or mysql etc...

5. KDC يرد:

- متشفّر بمفتاح سري TGS.
- القديم Session Key جديد متشفّر بالـ Session Key.

6. اليوزر دلوقتي معاه TGS → يقدر يدخل على الخدمة.

